

CYBER SECURE SOLUTIONS

Gestion d'une attaque avancée par ransomware

Type: plan_reponse_ransomware

Date: 3/31/2025
Référence: Gestion de crise cyber
Destinataire: eddy

****PLAN DE RÉPONSE À UNE ATTAQUE PAR RANSOMWARE****

****Contexte de formation****

****Domaine : Gestion de crise cyber****

****Scénario : Attaque avancée par ransomware****

****Niveau de difficulté : Expert****

****Contact : Lorenzo Bertola****

****Destinataire : Eddy****

****1. Introduction****

Une attaque par ransomware avancée a été détectée dans l'environnement système de l'entreprise. Les indicateurs initiaux montrent une compromission étendue, incluant des mécanismes de propagation latérale et un chiffrement progressif des données critiques. Cette simulation est destinée à tester votre aptitude à gérer une crise cyber complexe, en suivant des méthodologies professionnelles de réponse et de rétablissement.

****2. Contexte opérationnel****

**2.1 Description de l'incident**

- ****Type d'attaque : **** Ransomware avancé avec chiffrement asymétrique.
- ****Vecteur d'entrée suspecté : **** Phishing ciblé ou exploitation de vulnérabilités connues (potentiellement CVE-2023-XXXX).
- ****Symptômes observés : ****
 - Multiples stations de travail affichant des messages de demande de rançon.
 - Accès à certains fichiers critiques bloqué (extension des fichiers modifiée).
 - Performances réseau dégradées (trafic inhabituel détecté).
 - Tentatives de communication vers des serveurs de commande et contrôle (C2) identifiés via l'analyse des journaux.

**2.2 Impacts identifiés**

- ****Systèmes touchés : **** Serveur de gestion des ressources humaines, bases de données client, et environnements de développement.
- ****Pertes potentielles : ****
 - Risque de divulgation d'informations sensibles (PII, données financières).
 - Interruption des opérations métier critiques.

- Dégradation de l'image de marque en cas de divulgation publique.

3. Infrastructure technique en place

3.1 Architecture réseau

- **Zones affectées** : Segment LAN interne (HR et Finance) et DMZ (serveur web exposé).
- **Technologies en usage** :
 - Pare-feu NGFW avec inspection Deep Packet.
 - Solutions EDR (Endpoint Detection and Response) déployées sur 70 % des postes.
 - Sauvegardes quotidiennes sur un NAS dédié, avec réplication sur un site distant.

3.2 Points de vulnérabilité potentiels

- **Logiciels obsolètes** : Serveur SQL exécutant une version non patchée.
- **Comptes privilégiés** : Absence d'application stricte de MFA (authentification multi-facteur) sur certains comptes administrateurs.
- **Monitoring réseau** : Manque de corrélation en temps réel des logs entre les outils SIEM et IDS/IPS.

4. Chronologie de l'incident

4.1 Déroulement

1. **Heure T-0** : Détection initiale par l'équipe SOC (multiples alertes de chiffrement).
2. **Heure T+1** : Identification d'un processus malveillant sur plusieurs endpoints via EDR.
3. **Heure T+3** : Analyse des journaux révèle des connexions anormales vers des IP externes (listées dans le fichier `C2\_servers.txt`).
4. **Heure T+6** : Confirmation de la compromission des sauvegardes locales.

4.2 Points d'inflexion critiques

- Le ransomware semble avoir utilisé un privilège escaladé pour accéder aux sauvegardes.
- La demande de rançon stipule un délai de réponse de 72 heures avant destruction des clés de décryptage.

5. Ressources disponibles pour la gestion de crise

5.1 Équipe impliquée

- **SOC (Security Operations Center)** : Analyse des indicateurs de compromission (IoCs).
- **IT Infrastructure** : Validation de l'intégrité des sauvegardes et des systèmes opérationnels.
- **Legal & Compliance** : Évaluation des obligations réglementaires (GDPR, CCPA).

5.2 Outils disponibles

- Solutions EDR (CrowdStrike Falcon, SentinelOne).
- Accès au SIEM (Splunk, Elastic Stack) pour corrélation d'événements.
- Copies des sauvegardes distantes (à vérifier).

6. Points spécifiques à analyser

- **Chiffrement** : Méthode utilisée (AES-256, RSA-2048 ?).
- **Propagation** : Techniques employées pour l'infection latérale (exploitation de SMB, RDP ?).
- **Communication** : Canaux utilisés avec les serveurs C2 (DNS ? HTTPS ?).

7. Documentation supplémentaire

- **Fichiers techniques**
 - `IoC\_report\_initial.csv` : Indicateurs de compromission détectés.
 - `C2\_servers.txt` : Liste des IP suspectes identifiées.
 - **Logs système**
 - `firewall\_logs\_2023-10-xx.log`
 - `endpoint\_activity.log`

Note importante : Ce document est une base de travail pour la gestion de crise. Il ne contient aucune solution directe. Votre rôle est d'établir une stratégie de réponse basée sur ces informations. Pour toute question ou clarification, contactez Lorenzo Bertola.

